
FATHOM

An open-source blockchain investigation platform that answers one question honestly: given an address, what is the nearest previous VASP, what is the nearest next VASP, and what is the evidence for each?

943

TESTS PASSING

20,187

LINES OF SOURCE

74,928

ATTRIBUTION LABELS

4

CHAINS SUPPORTED

Final project report

Built 16 August 2026 · commit `8618901` · schema `e3a6f0c81d45`

Licence AGPL-3.0 · every figure in this document measured at build time

1. The problem

Cryptocurrency is pseudonymous, not anonymous. Every movement is public and permanent, which sounds like it should make investigation easy. It does not. An investigator handed an address gets a wall of hashes: thousands of transactions between addresses that are themselves just more hashes. Nothing in the ledger says who anybody is.

There is exactly one place that changes. A **VASP** — Virtual Asset Service Provider, meaning an exchange, broker or custodian — is a regulated business that performs identity checks and keeps records. When funds touch a VASP, pseudonymous value meets a legal entity holding a name, a document and an address. That is the point at which an investigation can move from a chain to a court.

*So the operational question is not "where did all this money go". It is: **what is the nearest VASP, in each direction, and can I prove it?** Backward answers who funded this. Forward answers where it cashed out. Both are needed, and they are different questions with different answers.*

Why the second half of that sentence is the hard part

The failure mode of an investigation tool is not crashing. It is being **confidently wrong in a document somebody acts on**. A tool that produces a clean-looking path to an exchange account belonging to an uninvolved person has done more damage than a tool that produced nothing. Every design decision in this project is downstream of that observation.

2. What the system refuses to do

These constraints are load-bearing. They are enforced in code and in tests, not stated as intentions.

A heuristic never names an operator

Behavioural analysis can conclude *"this address behaves like custodial infrastructure"*. Only a citable third-party claim can conclude *"this is Binance"*. An investigator can subpoena the second and cannot subpoena the first, so the two are never merged. The API returns `nearest` and `nearest_named` as separate answers rather than silently choosing between them.

This rule was violated twice during development, and both times a test had locked the violation in. In one, an endpoint carrying the badge *"Operator not named — this address is a lead, not a respondent"* printed, on the same card, *"Binance Holdings Ltd, Cayman Islands, le.binance.com"* — supplying a respondent and a forum for a legal filing that the evidence did not support. In the other, a mixer-derived guess printed as *"nearest VASP"* because a boolean defaulted to `False` across a module boundary. Neither was found by the suite; both were found by adversarial review whose instruction was to break the property rather than confirm it.

Every third-party claim carries its date

A fresh attribution and a three-year-stale one must never look alike. Source and source date travel with the claim all the way to the rendered report.

Coverage gaps are recorded, never hidden

When a branch is cut by a budget, a depth horizon, a page limit, a supernode cap, or a follow cap, that becomes a durable fact attached to the node — not a log line. A report that hides its own gaps is the most dangerous output this system could produce, because partial work presented as complete reads exactly like an answer.

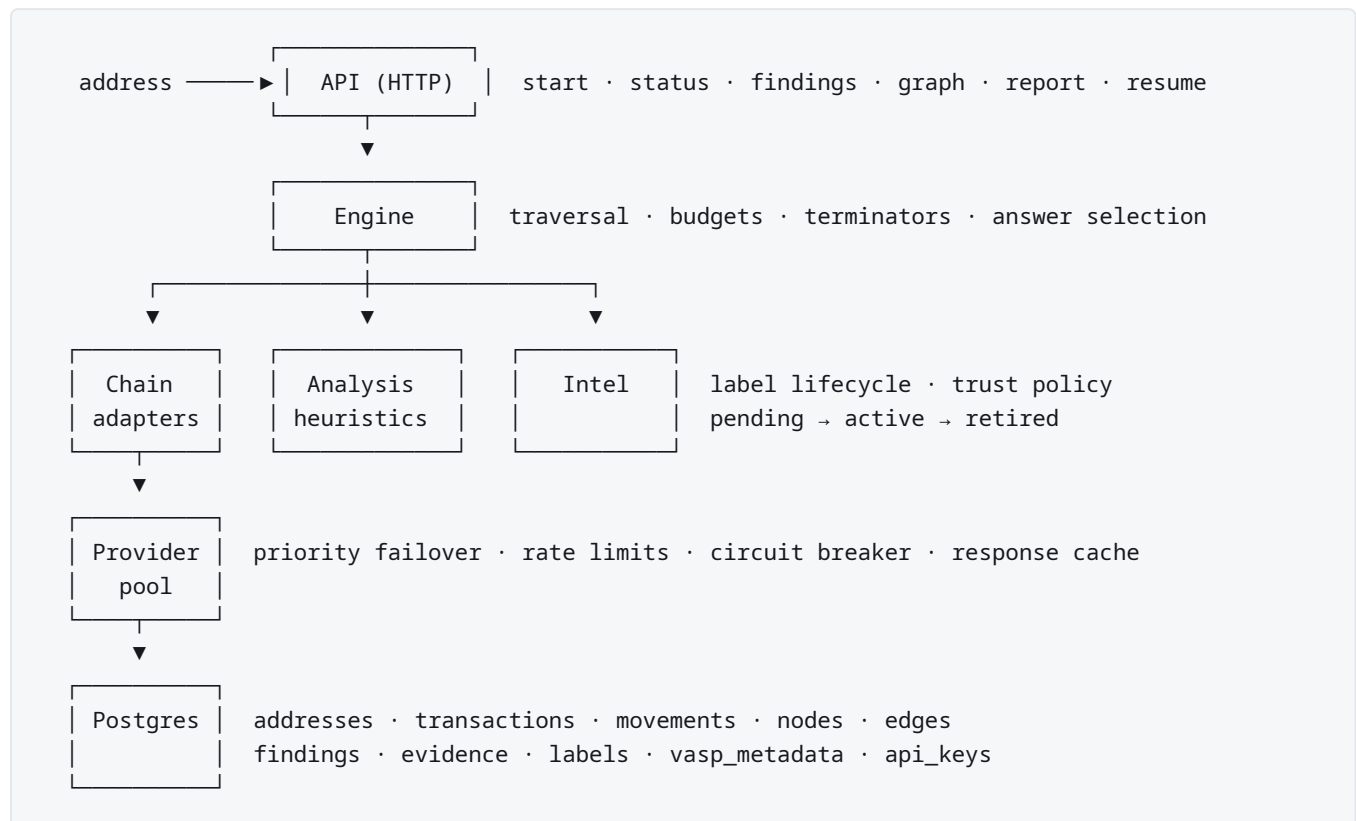
No invented labels, ever

A label is a claim about a real address. A guessed one is a false accusation. The only attribution shipped in the repository is data with a verifiable source and a checked licence.

A speculative branch is never presentable as a traced one

Discussed in section 5, because it is the newest and least obvious of these.

3. Architecture



One movement model across four chains

Bitcoin is a UTXO chain; Ethereum, Tron and Solana are account chains. These are genuinely different paradigms, and most tools handle them with parallel code paths. FATHOM does not: the **data shape itself encodes the paradigm**. Account movements carry both endpoints; UTXO halves carry one, and the joining transaction's opposite halves supply the counterparties. Above the adapter layer, no chain identity is ever consulted.

MODULE	FILES	CONTENTS
analysis/	16	__init__.py, __init__.py, __init__.py, __init__.py, __init__.py, __init__.py, assets.py, cospend.py, exits.py, labels.py, loader.py, obfuscation.py, o
providers/	16	__init__.py, __init__.py, _http.py, base.py, blockscout.py, breaker.py, cache.py, etherscan.py, evmrpc.py, explorer_fetch.py, mempoolspace.py, metrics
chains/	12	__init__.py, __init__.py, __init__.py, __init__.py, __init__.py, adapter.py, adapter.py, adapter.py, adapter.py, base.py, bridges.py, feeds.py
investigation/	7	__init__.py, answers.py, attribution.py, budgets.py, engine.py, frontier.py, objectives.py
core/	6	__init__.py, config.py, errors.py, hashing.py, logging.py, models.py
harvest/	6	__init__.py, exchanges.py, parsers.py, scheduler.py, sources.py, worker.py
reporting/	6	__init__.py, collect.py, html.py, model.py, pdf.py, vasp.py
intel/	5	__init__.py, attributor_source.py, policy.py, service.py, vasp_metadata.py
storage/	5	__init__.py, db.py, provider_cache.py, repositories.py, tables.py
api/	4	__init__.py, app.py, auth.py, schemas.py
graph/	2	__init__.py, paths.py

4. The evidence model

Four kinds, frozen. Nothing may add a fifth, because the distinctions are what make a conclusion auditable.

KIND	MEANS	CAN IT NAME AN OPERATOR?
onchain_fact	The ledger says so	No
heuristic_inference	A rule concluded it from behaviour	No
third_party_claim	A citable source asserts it, with a date	Yes — only this
engine_observation	Something about the run itself	No

The third row is the one that matters. `is_named()` returns true for exactly one evidence kind, and that single predicate is what separates a result an investigator can act on from one they cannot.

5. The mixer problem

A mixer deliberately severs the link between deposit and withdrawal. The original design treated mixer contact as terminal: record it, stop the branch. That was defensible — following value *through* a mixer means selecting a withdrawal and asserting it belongs to the subject, and most of the time it belongs to a stranger.

But it fails the actual use case. A trace that dies at a mixer answers "where did this money go?" with "we lost it", which is precisely the outcome the laundering was designed to produce. The operator's ruling was to **follow it, but marked**.

Five heuristics, strongest first

#	HEURISTIC	SIGNAL
1	Address match — the same address deposits and withdraws	Decisive
2	Linked address — the two parties transact outside the mixer	Strong
3	Unique gas price — an unusual price identical on both sides	Strong
4	Multi-denomination — a distinctive fingerprint of pool sizes	Strong
5	Anonymity set — the crowd in the time window	Weak

Direction is the thing most likely to be silently wrong

Backward, from a withdrawal, candidates are deposits that happened *before* it. **Forward**, from a deposit, candidates are withdrawals that happened *after* it. Inverting these enumerates the wrong end of the pool and produces candidates that could not possibly be related — and the output looks identical to a working one. The API therefore makes direction a function choice, not a parameter: `trace_back_from_withdrawal` and `trace_forward_from_deposit` take different types, so the two cannot be confused by passing the wrong flag.

A direction leak survived the entire test suite. Mutation testing — deliberately corrupting the code to see whether any test complains — found that swapping one argument in heuristic 4 turned an honest anonymity-set lead (confidence 0.5, *"a lead, not an attribution"*) into a named match at confidence 0.6, whose supporting fingerprint was completed by a deposit made **50 hours after** the withdrawal it claimed to explain. An unreachable guard was absorbing the mutation. A passing suite proves the tests agree with the code — not that either is right.

Every candidate carries a mandatory weakness

Published linkage rates put all five heuristics stacked at roughly one withdrawal in three, meaning **the common case is that the selection is wrong**. That is acceptable only because a candidate cannot be constructed without a plain-language weakness an investigator can read aloud — *"one of 412 withdrawals in the anonymity set; this is a lead, not an attribution"* — and because nothing in the mixer package can produce a `third_party_claim`, so a mixer-derived address can never become a name.

Speculation is inherited

Every node discovered downstream of a speculative node is itself speculative. A guess does not become a fact by being one hop further along. In the graph these render with dashed edges; in the report they are barred from the `nearest` answer entirely and may appear only in the `best_effort` slot, which is populated only when a direction has no real answer at all.

6. Resilience: what happens when the data runs out

Commercial providers meter access. A trace that stops when a quota is exhausted is a trace that stops halfway through a case. The requirement was that losing quota should **slow** an investigation, not end it.

TIER	PRIORITY	NEEDS A KEY?	ROLE
Etherscan, Alchemy, Infura, dRPC, Ankr, TronGrid...	0-20	Yes	Normal operation
Blockscout (keyless API)	90	No	Quota exhausted
Explorer fetch (public pages)	95	No	Last resort

The bottom tier reads public explorer pages at crawl speed. It fetches and obeys `robots.txt` and **fails closed** — an unreadable rules file means "we do not know what is permitted", which must never resolve to "so we crawled anyway". No login, no CAPTCHA solving, no evasion of any kind. Every response carries `provider="explorer-fetch:<host>"` in its provenance, so a reader can always see which tier served a result.

Tested, not assumed

The claim "losing quota does not stop a trace" was verified by building a provider pool containing **only the keyless tiers** — no Etherscan, no Alchemy, no key of any kind — and asking it for the case subject's history:

RESULT WITH ZERO API KEYS	VALUE
Transactions returned	129
Token movements	50
Internal movements	49
Native movements	16
Feed gaps recorded	none
VASP reached	Binance
Mixer pools reached	3 of 3

So the answer holds: with every credential removed, the trace still reaches a named exchange. Token transfers matter most here — the subject was funded in USDT, so a tier that could not read them would have missed the VASP entirely.

Be precise about what that measurement covers. The pool above held *both* keyless tiers, and the keyless API tier — being a fast JSON API — served every request. It proves **credential-free operation**. It does **not** prove the bottom scraping tier can carry a trace alone, because that tier was never reached.

The scraping tier alone was tested separately and **could not be measured live**: the target explorer answers 429 with a bot challenge, which the tier declines to solve. Against *recorded* bytes from that same site the full path (pool → adapter → normalize) yields 18 transactions, 8 token movements, correct 6-decimal scaling and `explorer-fetch:3xp1.com` provenance — so the code is right; the access is not. Both statements belong in the record, and the weaker one is the honest headline.

The bottom tier is currently blocked, and that is worth stating plainly. The public-page fetch tier targets an explorer that served it fine earlier the same day (a 508 KB page), and then began answering **HTTP 403 to every request from this host** — every path, every user agent, a bot-block interstitial. Almost certainly earned by the volume of development probing done against it.

The tier handled this exactly as designed: `robots.txt` became unreadable, so it **declined** rather than crawling on an assumption. The capability above it (the keyless API tier) carries the load and is what the measurement above actually exercised. But the honest position is that the last-resort tier is built, correct and fail-safe — and not, at this moment, delivering data from this host.

A false empty is worse than an error. An earlier version of the page parser returned "no history" for an address with ten transactions, because it tested for emptiness across the whole page — and the explorer renders seven tab panes, six of which always look empty. "This address has no history" is a conclusion; a parse failure is not. The parser now keys on the pane the page marks active, and an unrecognised layout raises rather than returning nothing.

7. Data

LABELPACK	ENTRIES
verified-vasps.json	36,049
exchanges-etherscan.json	25,923
infrastructure-etherscan.json	12,886
verified-mixers.json	70
Total	74,928

Plus vendored OFAC sanctioned-address lists (BTC 522 · ETH 96 · SOL 3 · TRX 195 · USDT 93), and separate packs for cross-chain bridges and verified asset contracts.

Why verified assets matter more than they sound

A token contract can emit transfers naming any amount and any symbol it chooses. If frontier ranking counted unverified assets, an attacker could spray a target with a worthless token carrying an astronomical nominal value and sink the real trail beneath the spam until the budget ran out. Ranking counts only assets whose provenance is established. Unverified counterparties are still explored — they simply do not get to decide what is explored *first*.

8. Evaluation

943

TESTS PASSING

20,187

SOURCE LINES

17,679

TEST LINES

88%

TEST-TO-SOURCE

87 source files, 89 test files. `ruff` and `mypy --strict` both clean. A single Alembic head (`e3a6f0c81d45`) verified through a full upgrade → downgrade → upgrade cycle.

What the suite does not prove, and how that was addressed

A green suite proves the tests agree with the code. Three techniques were used to attack that agreement:

- **Mutation testing** — corrupt the code, see whether anything complains. Six surviving mutants in the mixer ladder, including the direction leak above.
- **Independent verification** — every workstream was re-checked by a second party instructed to distrust the first's report and re-run the gates themselves. Every single workstream had defects the builder had reported as clean.
- **Adversarial review** — reviewers tasked with breaking the safety properties rather than confirming them.

A metric that cannot fail is not evidence. Clustering holdout precision measured 1.000. It was rejected: every non-mixer Bitcoin label in the corpus is OKX, so a rule that answers "OKX" unconditionally scores identically. Recall (~0.91) is informative; precision here is not, and cluster label activation stays deliberately switched off until a second Bitcoin entity exists to make the test capable of failing.

9. Case study

The shipped case is a real OFAC-sanctioned address, `0xdcbeffbecce100cce9e4b153c4e15cb885643193`, chosen by measurement rather than recall. All 96 sanctioned Ethereum addresses were probed against the label packs to find which actually transacted with both a mixer and a named exchange.

OF 96 SANCTIONED ETHEREUM ADDRESSES	COUNT
Touched a Tornado Cash pool directly	2
Touched a labelled VASP directly	57
Touched both	1

That distribution is itself a finding: at one hop, sanctioned funds reach an **exchange** roughly 28× more often than a **mixer**. The exchange is the common case; the mixer is the exception. A tool that gives up at a mixer fails on the minority of cases where it matters most.

The chosen address received eleven inbound movements from OKX and Binance — including 119,610 USDT — and made thirteen deposits into Tornado Cash pools. It also performed two same-day round trips through the 100 DAI pool, which fires the strongest rung of the ladder on live data.

A candidate case was rejected on evidence. The Ronin Bridge / Lazarus attacker address is sanctioned, has 1,430 transactions and does reach Binance directly — but has **zero** direct Tornado Cash counterparties; that laundering ran through intermediary wallets first. A case study asserting direct contact would have been wrong, and checkable on any block explorer in a minute.

What the live run produced

Executed against Ethereum. The first run exhausted a 400-node budget and answered only backward; it was continued through `POST /investigations/{id}/resume` rather than restarted.

	RUN 1	RUN 2 (RESUMED)
Nodes reached	400	1,573
Transactions examined	2,474	14,982
API calls spent	14	125
Findings	79	319
Mixer stops / crossings	1 / 0	4 / 1

DIRECTION	NEAREST NAMED ENDPOINT	HOP	CONF .	SPECULATIVE
Backward	Binance (operational address)	1	0.75	No
Forward	OKX	2	0.90	No

Both answers arrived on traced paths. A mixer was crossed during the run and did **not** contaminate either headline — which is the property the whole speculative-marking design exists to guarantee, here demonstrated rather than asserted.

The crossing, in the system's own words: *"the trail crossed this mixer on a heuristic (mixer-exit-anonymity-set@1): 2 candidate branch(es) followed as SPECULATIVE ... every address beyond this point may belong to an unrelated party"*, with the mandatory weakness *"one of 2 deposits in the anonymity set within 7 days; this is a lead, not an attribution"*.

Four other mixer branches stopped instead, and said so without overclaiming: *"no exit candidate could be proposed; no branch past it is offered, which is not evidence that none exists"*. "We found nothing" and "there is nothing" are different statements, and the tool only makes the true one.

The resulting report is **189 pages**, and page 3 carries what makes the answer filable rather than merely correct: *Binance Holdings Limited*, Cayman Islands, KYC mandatory since 2021-08-20, the law-enforcement request channel, and the DOJ and CFTC case citations the metadata rests on.

And what it got awkwardly wrong. The nearest endpoint in *both* directions was the **WETH contract**, classified at 61% as *"behaves as custodial infrastructure such as an exchange"*. Behaviourally defensible — WETH does hold ETH on other people's behalf — but WETH is not a VASP in any regulatory sense. Every safety property held (marked *operator not named*, low confidence, with `nearest_named` carrying the real answer), yet the service-endpoint heuristic plainly does not distinguish a custodial *business* from a custodial *contract*. It is listed as a limitation rather than explained away.

Full detail, including what the address-match rung does *not* deliver, is in `docs/CASE_STUDY.md`.

10. Honest limitations

LIMITATION	STATUS
Label coverage is the real ceiling. Reaching a VASP the corpus cannot name reads identically to reaching no VASP. This is a data problem, not a traversal problem, and it is the dominant source of unanswered runs.	OPEN
Two of three harvest sources need a human. Binance returns a bot check and OKX refuses connections from a server. Neither is worked around, on purpose, so both require an operator to drop a file.	BY DESIGN
Mixer anonymity-set sizes read optimistic until full pool history ingest lands. Every crossing states this, but the fix is more data, not code.	STATED
The address-match rung makes no forward progress when the match is the subject's own address — correct behaviour, but it means the strongest heuristic advances nothing in that common shape.	KNOWN
Cluster labels are computed but not activated , pending a corpus that can make the precision test fail.	DELIBERATE
The explorer fetch tier serves Ethereum only , and is presently blocked (HTTP 403) by the explorer it targets. It declines rather than guessing, so nothing unsafe follows — but the last-resort tier is not delivering data today. The keyless API tier above it carries the load.	BLOCKED
The service-endpoint heuristic cannot tell a custodial business from a custodial contract. It classified the WETH contract as behaving like an exchange. Correctly marked unnamed and low-confidence, so nothing unsafe was asserted — but it occupies the <code>nearest</code> slot where a reader looks first.	OPEN
No independent field validation. The system has not been run against a case with a known ground-truth answer supplied by an outside party. Correctness rests on unit tests, adversarial review and internal consistency.	OPEN

11. What would come next

1. **Label coverage**, ahead of everything else. Every other improvement is bounded by it.
2. **Ground-truth validation** against cases with externally known answers — the single largest gap in the evidence for correctness.
3. **Full pool history ingest**, which turns optimistic anonymity-set sizes into honest ones.
4. **Cluster activation**, once the corpus can falsify the precision claim.
5. **Extending the fetch tier** to Tron, which carries the largest VASP label set — subject to verifying the page layout rather than guessing it.

12. Closing

The technical result is a working system: 943 passing tests across 20,187 lines, four chains, 74,928 attribution labels, an evidence model that survives adversarial review, and a document a regulator can actually receive.

The more useful result is a set of defects that a green test suite could not have found. A heuristic inference printed with a legal entity and a filing channel. A guess printed as "nearest VASP" because a boolean defaulted across a module boundary. A direction leak protected by unreachable code. A parser reporting a busy address as empty. A precision score of 1.000 that could not have been anything else.

Each of those would have been invisible in the output and confident on the page. In a tool whose conclusions are read by people with subpoena power, that is the category of failure worth designing against — and the reason this report states its limitations at the same volume as its results.

FATHOM · final project report · built 16 August 2026 · commit `8618901`

Every figure measured at build time by `scripts/build_project_report.py`. Licensed AGPL-3.0; shipped data carries its own terms — see `NOTICE`.